

Acme Corp - Information Security Policy

Policy ID: ACME-IT-001

Effective Date: January 1, 2026

Last Revised: January 1, 2026

Approved By: David Park, Chief Information Security Officer (CISO)

Applies To: All Acme Corp employees, contractors, and third-party service providers with access to Acme Corp systems or data

1. Purpose

This policy establishes the information security requirements for protecting Acme Corp's digital assets, systems, and data. All employees are responsible for safeguarding company information and complying with the security measures outlined in this document.

2. Data Classification

All Acme Corp data must be classified according to the following levels:

Classification	Description	Examples	Handling Requirements
Public	Information approved for public release	Marketing materials, press releases	No restrictions on sharing
Internal	General business information not for public release	Internal memos, org charts, HR records	Share only with Acme employees
Confidential	Sensitive business information	Financial reports, strategic plans	Encrypt at rest and in transit
Restricted	Highly sensitive data with legal implications	Social Security numbers, payment card data	Encrypt with AES-256; strict access controls

When in doubt about data classification, treat the data as Confidential and consult the Security team.

3. Password and Authentication Requirements

3.1 Password Policy

All Acme Corp accounts must use passwords that meet the following requirements:

- Minimum length: 14 characters
- Complexity: Must include at least three of the following four categories: uppercase letters, lowercase letters,

numbers, and special characters (!@#\$%^&*)

- Expiration: Passwords must be changed every 90 days
- History: Cannot reuse any of the last 12 passwords
- Lockout: Accounts are locked after 5 consecutive failed login attempts; unlock requires contacting IT Support

3.2 Multi-Factor Authentication (MFA)

MFA is mandatory for all Acme Corp accounts, including:

- Email (Google Workspace)
- VPN access
- Cloud services (AWS, GCP, Azure)
- The Acme HR Portal
- The Acme Expense Portal
- Code repositories (GitHub Enterprise)
- Any system containing Confidential or Restricted data

Approved MFA methods: hardware security keys (preferred), authenticator apps (Google Authenticator, Authy). SMS-based MFA is not permitted due to SIM-swap vulnerabilities.

3.3 Password Manager

All employees must use the company-provided password manager (1Password Enterprise) to generate and store unique passwords for each account. Sharing passwords via email, Slack, text message, or any unencrypted channel is strictly prohibited.

4. Device Security

4.1 Company Devices

All company-issued devices must:

- Have full-disk encryption enabled (FileVault for macOS, BitLocker for Windows)
- Run an approved endpoint detection and response (EDR) agent (CrowdStrike Falcon)
- Have the operating system and all software updated within 7 days of a security patch release
- Have the company VPN client installed and configured
- Have automatic screen lock enabled after 5 minutes of inactivity
- Be protected by a strong login password or biometric authentication

4.2 Personal Devices (BYOD)

Personal devices may be used for accessing Acme Corp email and Slack under the following conditions:

- The device must have a screen lock with a minimum 6-digit PIN or biometric authentication
- The device must run a supported operating system (iOS 17+, Android 14+, macOS 14+, Windows 11+)
- The employee must enroll the device in Acme Corp's Mobile Device Management (MDM) system
- Acme Corp reserves the right to remotely wipe company data from personal devices upon separation or security incident

4.3 Lost or Stolen Devices

Report any lost or stolen company or personal device containing company data immediately to:

- IT Security: security@acmecorp.com or extension x4700
- Available 24/7 via the emergency security hotline: (555) 867-5309

IT Security will initiate a remote wipe and password reset within 1 hour of notification.

5. Network and Access Security

5.1 VPN Requirements

Employees must use the Acme Corp VPN when:

- Working remotely on any network outside an Acme Corp office
- Accessing Confidential or Restricted data from any location
- Connecting to any Acme Corp internal service or database

The VPN is not required for accessing public-facing services (e.g., the Acme website, public documentation).

5.2 Wi-Fi Security

- Public Wi-Fi (coffee shops, airports, hotels): VPN must be active at all times; never access Restricted data.
- Home Wi-Fi: Must be secured with WPA3 or WPA2 encryption and a strong unique password.
- Acme Corp Office Wi-Fi: Secured via WPA3 Enterprise with certificate-based authentication.

5.3 Access Control

Acme Corp follows the principle of least privilege: employees are granted only the minimum access necessary to perform their job functions.

- Access to systems and data is provisioned through the IT ticketing system.
- Access is reviewed quarterly by each department's manager and the Security team.

- Access is revoked within 4 hours of an employee's separation (voluntary or involuntary).
- All access changes are logged and auditable.

6. Email and Communication Security

6.1 Email Security

- Do not click on links or open attachments from unknown or suspicious senders.
- Report all suspected phishing emails by clicking the "Report Phishing" button in Gmail or forwarding to phishing@acmecorp.com.
- Do not send Confidential or Restricted data via email unless encrypted using the company-approved encryption tool.
- External email auto-forwarding is disabled for all Acme Corp accounts.

6.2 Phishing and Social Engineering

- Acme Corp conducts monthly phishing simulations to test employee awareness.
- Employees who fail phishing simulations will be assigned mandatory security awareness training within 5 business days.
- Employees who fail 3 or more phishing simulations within a 12-month period will have their case reviewed by Security and HR.

6.3 Messaging and Collaboration

- Use Slack for internal team communication (Slack is preferred over email for most internal conversations).
- Do not share Restricted data in Slack channels; use approved secure file-sharing methods instead.
- External Slack guests must be approved by the Security team and are limited to specific channels.

7. Software and Application Security

7.1 Approved Software

Only software from the Acme Corp Approved Software List may be installed on company devices. The approved list is maintained on the IT intranet and updated monthly.

To request approval for new software:

1. Submit a Software Approval Request via the IT ticketing system.

2. IT Security will evaluate the software within 10 business days.
3. Approved software will be added to the company software catalog.

7.2 Prohibited Software

The following categories of software are prohibited on company devices:

- Peer-to-peer file sharing applications (e.g., BitTorrent clients)
- Unauthorized VPN or proxy services
- Cryptocurrency mining software
- Personal cloud storage applications for work files (use Google Drive only)
- Any software that has known unpatched critical vulnerabilities

7.3 Software Updates

All software on company devices must be kept up to date. Critical security patches must be applied within 7 calendar days of release. Operating system updates must be applied within 14 calendar days.

8. Data Protection and Privacy

8.1 Data Handling

- Confidential and Restricted data must be stored only on approved company systems (Google Drive, company databases, approved cloud services).
- Do not store Confidential or Restricted data on personal devices, USB drives, or unauthorized cloud services.
- Restricted data must be encrypted at rest using AES-256 encryption and in transit using TLS 1.2 or higher.

8.2 Data Retention and Disposal

- Data must be retained according to the Acme Corp Data Retention Schedule maintained by Legal.
- When data reaches end-of-life, electronic data must be securely deleted using approved wiping tools.
- Physical media (hard drives, USB drives, paper) must be securely destroyed through the IT-managed disposal program.

8.3 Customer Data

Customer data is classified as Confidential at minimum, with personally identifiable information (PII) classified as Restricted. Employees handling customer data must:

- Complete annual Data Privacy Training

- Follow all applicable privacy regulations (GDPR, CCPA, etc.)
- Report any suspected data breach immediately to the Security team

9. Incident Response

9.1 Reporting Security Incidents

All employees must immediately report suspected security incidents to:

- Email: security@acmecorp.com
- Slack: #security-incidents channel
- Phone: (555) 867-5309 (24/7 emergency line)

Security incidents include but are not limited to:

- Unauthorized access to systems or data
- Malware infection or suspicious system behavior
- Phishing attacks (successful or attempted)
- Lost or stolen devices containing company data
- Accidental disclosure of Confidential or Restricted data
- Suspicious physical access to Acme Corp offices

9.2 Incident Response Process

1. Identification: Security team assesses the reported incident within 30 minutes.
2. Containment: Affected systems are isolated to prevent further damage.
3. Eradication: The root cause is identified and eliminated.
4. Recovery: Systems are restored to normal operation.
5. Post-Incident Review: A post-mortem report is produced within 5 business days and shared with relevant stakeholders.

9.3 Breach Notification

In the event of a confirmed data breach involving Restricted data (especially PII), Acme Corp will:

- Notify affected individuals within 72 hours of confirmation.
- Notify relevant regulatory authorities as required by law.
- Engage external forensic investigators if necessary.
- Provide affected individuals with credit monitoring services for 12 months.

10. Security Awareness Training

10.1 Required Training

All employees must complete the following training:

Training	Frequency	Duration
Security Awareness Fundamentals	Annual	45 minutes
Phishing Recognition	Semi-annual	20 minutes
Data Privacy and Classification	Annual	30 minutes
Secure Coding Practices	Annual (engineering only)	60 minutes

10.2 New Hire Training

New employees must complete Security Awareness Fundamentals and Data Privacy training within their first 5 business days.

11. Physical Security

- All Acme Corp offices use badge-based access control. Employees must not share, lend, or duplicate their access badges.
- Visitors must sign in at reception and be escorted by an Acme Corp employee at all times.
- Sensitive areas (server rooms, executive offices) require additional badge authorization.
- Report any unauthorized physical access attempts to security@acmecorp.com.

12. Third-Party and Vendor Security

All third-party vendors with access to Acme Corp data or systems must:

- Complete a security assessment before onboarding.
- Sign a data processing agreement (DPA) that includes security requirements.
- Maintain compliance with SOC 2 Type II or equivalent security standards.
- Submit to annual security reviews by the Acme Corp Security team.

13. Policy Violations

Violation of this Information Security Policy may result in:

- Mandatory additional security training
- Restriction or revocation of system access
- Disciplinary action, up to and including termination
- Legal action for intentional or grossly negligent violations that result in data breach

All policy violations are tracked and reviewed quarterly by the CISO and VP of Human Resources.

14. Policy Compliance and Questions

Employees with questions about this policy should contact the IT Security team at security@acmecorp.com or extension x4700.

This policy is subject to change at the discretion of Acme Corp management. Employees will be notified of material changes via email and the Acme HR Portal.